

THE 12 REQUIREMENTS

Properly covering the 12 requirements of PCI-DSS, as well as what each consists of.





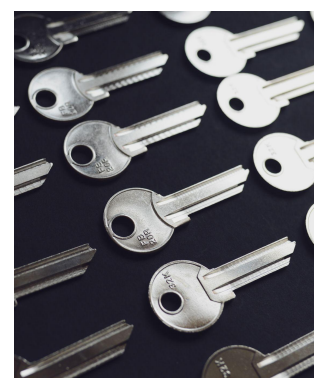
THE 12 REQUIREMENTS

To properly cover the 12 requirements,
we covered **twelve topics** - one for each:



REQ. 1: FIREWALL

Keeping a firewall configuration, as
well as documentation and
change management.



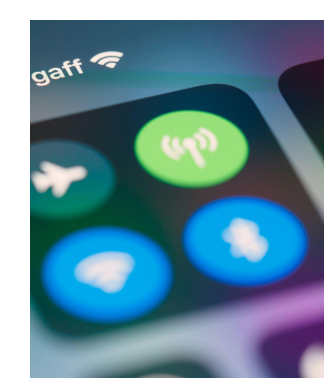
REQ. 2: NO DEFAULTS

Removing all default accounts,
passwords and others from
devices.



REQ. 3: STORED DATA

Protecting stored data in the
database with strong encryption
measures.



REQ. 4: TRANSM. DATA

Protecting data transmitted across
networks with strong encryption
and masking.



THE 12 REQUIREMENTS

To properly cover the 12 requirements,
we covered **twelve topics** - one for each:



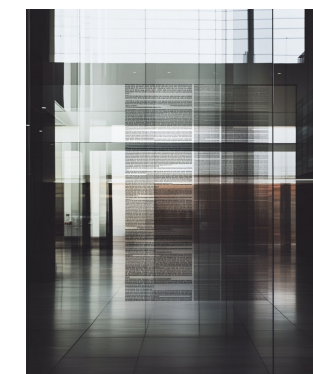
REQ. 5: NO MALWARE

Maintaining an antivirus program
to prevent malware from entering
your systems.



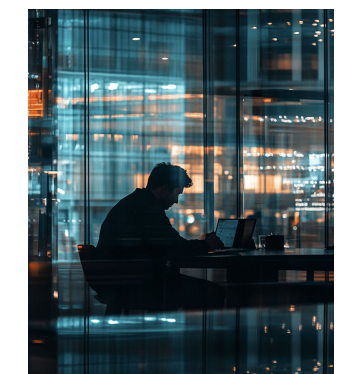
REQ. 6: SECURE DEV

Maintaining secure development
practices, as well as timely
patching of vulnerabilities.



REQ. 7: NEED-TO-KNOW

Restricting access to cardholder
data on a need-to-know basis.



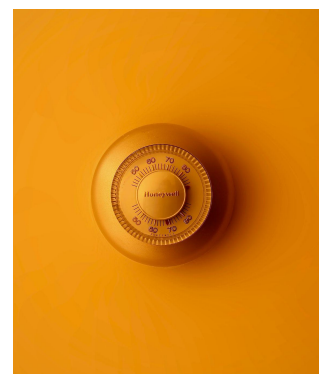
REQ. 8: IDENTIFYING

Procedures to attribute access to
specific users, for accountability.



THE 12 REQUIREMENTS

To properly cover the 12 requirements,
we covered **twelve topics** - one for each:



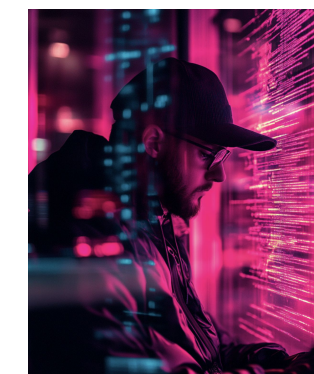
REQ. 9: PHYSICAL ACCESS

Restricting physical access to
rooms, physical media, and more.



REQ. 10: MONITORING

Proper logging of different
activities of different systems.



REQ. 11: REGULAR TESTS

Regularly testing, internally and
externally, to prevent intrusions.



REQ. 12: INFOSEC POLICY

Having an organisation-wide set of
policies and procedures for
information security.



THE 12 REQUIREMENTS

THE 12 REQUIREMENTS **CONSOLIDATING**

Some questions you can ask yourself to consolidate the knowledge in this module (as of v4.0.0) include:

- What are some examples of measures that must be taken to ensure strong cryptography? (Algorithms and keys);
- What are some examples of frequent vulnerabilities to protect against when developing?
- What types of files should be subject to FIM?
- What's the policy for users to turn off their AV/firewall?
- What does the Principle of Least Privilege (PoLP) defend?
- What two diagrams are crucial in Requirement 1?
- What's the deadline to apply critical patches? What about all other patches?